

Task 1 — Web App QA & Debug Report

Rikk Bera | RealWorld Demo — <https://demo.realworld.show>

Application tested: RealWorld Demo (demo.realworld.show)

Finding count: 5

1. Issues Found

#	Title / Summary	Steps to Reproduce	Expected vs Actual	Severity	Suspected Cause
1	Invalid email accepted during registration	1. Open the RealWorld demo and select Sign Up. 2. Enter a unique username. 3. Enter an invalid email such as `rikk@`. 4. Enter a password and submit.	Expected: The application should reject the invalid email format and display a validation message. Actual: The registration was accepted even though the email address was not in a valid email format.	Medium	Email-format validation is insufficient or is not enforced consistently during registration.
2	Non-existent URL does not display a proper 404 page	1. Open `https://demo.realworld.show/this-page-does-not-exist`. 2. Observe the page rendered for the invalid route.	Expected: The application should display a clear 404 / Page Not Found state. Actual: The invalid route displays the application's normal/blank branded page instead of a clear 404 error state.	Medium	The frontend routing configuration does not provide a dedicated fallback route/component for unknown URLs.
3	Comment sign-in redirects to Home instead of returning to the article	1. While logged out, open any article. 2. Scroll to Comments. 3. Click "Sign in or sign up to add comments on this article." 4. Complete the sign-in flow. 5. Observe the destination.	Expected: After authentication, the user should return to the same article to continue commenting. Actual: The user is redirected to the Home page instead of being returned to the article.	Medium	The authentication flow does not preserve and restore the originating article route after sign-in.
4	Popular Tags does not appear to reflect actual tag popularity	1. Open the RealWorld home page. 2. Observe the "Popular Tags" section. 3. Compare the displayed tags with tags associated with the currently shown articles.	Expected: Popular Tags should represent tags according to their popularity/usage across articles. Actual: The section appears to list tags used by the displayed articles rather than clearly reflecting a popularity-ranked set of tags.	Medium	The displayed tag list does not appear to be clearly derived from a popularity-ranked aggregation of tag usage.
5	Sensitive account credentials can be changed without re-authentication	1. Sign in to a test account. 2. Open Settings. 3. Change the registered email address and/or password. 4. Submit without entering the current password or completing an additional authentication step. 5. Observe whether the changes are accepted.	Expected: Changing sensitive account credentials should require appropriate re-authentication or verification. Actual: The email/password can be changed from the authenticated Settings session without an additional re-authentication step.	High	The settings update flow relies on the existing authenticated session without step-up authentication for sensitive credential changes.

2. Root-Cause Analysis — Sensitive Credential Changes Without Re-authentication

The most significant finding is the ability to change sensitive account credentials without re-authentication. The Settings flow accepts credential changes based on the existing authenticated session rather than requiring the user to verify the current password or complete another step-up authentication mechanism. This means possession of an active authenticated session may be sufficient to modify the account email or password. Changing the email can affect account recovery and future account communications, while changing the password can affect subsequent account access. The issue is therefore primarily an authorization and account-security control problem rather than a basic login failure. A stronger design would require the current password or another appropriate verification factor before allowing sensitive credential changes. The server should enforce this requirement rather than relying only on frontend validation, because client-side checks can be bypassed. The Settings endpoint should validate the user's authorization and reject sensitive changes when the required re-authentication evidence is missing.

3. QA Notes

- The five findings above are based on manual verification against the live RealWorld demo.
- Issue 4 is phrased as an observation because tag popularity was assessed from the visible UI rather than a full backend data audit.
- Issue 5 is classified High because email/password changes are sensitive account operations and were observed without an additional re-authentication step.
- Article deletion, article editing, tag clicking, pagination, default avatar behavior, and invalid-login handling were tested and worked as expected during the assessment.

4. Recommended Next Steps

- Add strict email-format validation on both client and server during registration.
- Implement a dedicated 404 / Page Not Found route for unknown URLs.
- Preserve the originating article route through authentication so users return to the article after sign-in.
- Ensure the Popular Tags data is generated/ranked from actual tag usage across the relevant article set.
- Require re-authentication or equivalent step-up verification before changing email or password, with server-side enforcement.